Texas Risk and Authorization Management Program (TX-RAMP) Program Manual

Version 4.0

Effective Date

This publication takes effect on February 12, 2026.

Table of Contents

1. Purpose **5**

2. Document Change Management **5**

2.1 New or Revised Program Standards 5

2.2 Administrative Changes 5

2.3 Inquiries 5

3. Overview **6**

4. Responsibilities **7**

4.1 Agency Responsibilities 7

4.2 TX-RAMP Responsibilities 7

4.3 Cloud Service Provider Responsibilities 7

5. Scope **9**

5.1 Cloud Computing Services 9

5.1.1 Essential Characteristics: 9

5.1.2 Service Models: 10

5.1.3 Deployment Models: 10

6. Cloud Services Not Subject to TX-RAMP Certification **11**

6.1 Non-substantive Use of Confidential State-controlled Data 11

6.2 Custom Developed Applications 11

7. TX-RAMP Control Baselines **13**

7.1 TX-RAMP Low Impact Baseline (TX-RAMP Level 1) 13

7.2 TX-RAMP Moderate or High Impact Baseline (TX-RAMP Level 2) 13

8. Minimum Baseline Determination **15**

9. TX-RAMP Certification **16**

9.1 TX-RAMP Certification Paths 16

9.2 Certification Via Other RAMPs 16

10. TX-RAMP Provisional Certification **19**

10.1 Provisional Certification Considerations 19

10.2 Failure to Attain Full Certification before Provisional Status Expiration 19

10.3 TX-RAMP Provisional Certification via Other RAMP 19

11. Assessment Process - Level 1 and Level 2 ..... **20**

12. Certification Extensions 23
12.1 TX-RAMP Provisional Certification Extensions 23
12.2 TX-RAMP Provisional Certification Extension Request Process 23
12.3 Extension while under TX-RAMP assessment review 23
12.4 Level 1 and Level 2 Certification Extensions 24
13. Transitional Grace Period 25
13.1 Purpose 25
13.2 Agency Responsibilities 25
13.3 Minimum Criteria for the Transition Plan 25
14. TX-RAMP Assessment Components 27
14.1 TX-RAMP Acknowledgment and Inventory Questionnaire 27
Cloud Service Provider Acknowledgment of Texas Security Requirements 27
Information Security Documentation Inventory 27
14.2 TX-RAMP Assessment Questionnaire 27
14.3 TX-RAMP Security Plan Workbook Best Practices 28
14.4 Plan of Action and Milestones (POA&M) 29
15. TX-RAMP Fast Track Assessment 30
15.1 TX-RAMP Fast Track Assessment Overview 30
15.2 Third-party Assessment Acceptance Criteria 30
15.3 Accepted Fast Track Documentation 30
15.4 TX-RAMP Level 1 Fast Track Assessment 31
15.5 TX-RAMP Level 2 Fast Track Assessment 31
15.6 Fast Track Request Process 32
15.7 Fast Track Continuous Monitoring 32
16. Assessment Considerations 33
16.1 Time Required to Complete Assessment Review 33
16.2 SaaS and Subservice Cloud Providers 33
16.3 Cloud Reseller Functions 33
17. Continuous Monitoring 34
17.1 Overview 34
17.2 Vulnerability Reporting 34
17.3 Reporting Breach of System Security 36

17.4 Significant Change Reporting 36
18. Dispute Resolution 38
18.1 Appeals Process 38
Request for Appeal to the State of Texas Chief Information Security Officer 38
Final Request for Appeal to the DIR Executive Director 38
18.2 Grievance Process 38
19. Certification Revocation 39
20. Recertification 39
21. Program Certification Change Management 41
21.1 Cloud Service Provider Control Changes Compliance Timeline 41
22. Document Version History 42
23. Appendix A – TX-RAMP Control Baselines 44
24. Appendix B – Required Documentation 44
25. Appendix C – Glossary of Terms 46
26. Appendix D – Acronyms 46

1. Purpose

Government Code Section 2063.408 requires the Texas Department of Information Resources (DIR) [1] to "establish a state risk and authorization management program to provide a standardized approach for security assessment, authorization, and Continuous Monitoring of cloud computing services that process the data of a state agency." In response to this mandate, DIR created the Texas Risk and Authorization Management Program (TX-RAMP).

The TX-RAMP Program Manual defines the processes, procedures, and compliance requirements relating to the use of cloud computing services by Texas state agencies.

2. Document Change Management

2.1 New or Revised Program Standards

Prior to publishing new or revised program standards, DIR shall solicit comments from state agency and institution of higher education Information Security Officers and Information Resources Managers, the Information Technology Council for Higher Education established by Government Code Section 2054.121, and any other stakeholders at DIR's discretion. After reviewing comments received from these stakeholders, DIR will present the proposed updates to the DIR Board of Directors and obtain approval from the Board for publication.

2.2 Administrative Changes

Administrative changes, such as formatting and grammatical corrections that are non-substantive may be implemented without seeking input from external stakeholders or board approval. Administrative changes to the Program Manual are denoted by minor version changes (e.g., "Version 1.0 to 1.1" denotes such administrative changes), whereas "Version 1.0 to 2.0" indicates major changes requiring adherence to the stated requirements listed in Section 2.1 New or Revised Program Standards.

Document version history may be found in Section 23 Document Version History.

2.3 Inquiries

Please direct questions to TX-RAMP@dir.texas.gov.

[1] In 2025, the Texas Legislature passed, and the Governor signed into law House Bill (HB) 150, which creates Texas Cyber Command and transfers to it DIR's cybersecurity duties, including TX-RAMP. Notwithstanding, HB 150 authorizes DIR to continue to perform duties and exercise powers under Texas Government Code Chapter 2054 as it existed prior to the passage of HB 150 until the date of the memorandum entered into between Texas Cyber Command and DIR identifies that all duties and responsibilities must transfer to Texas Cyber Command.

3. Overview

TX-RAMP provides a standardized approach to the security assessment of cloud computing services. Government Code Section 2157.007 states that a "Cloud Computing Service" has the meaning assigned by the United States Department of Commerce National Institute of Standards and Technology (NIST) Special Publication 800-145. Cloud computing is "a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction."

- Government Code Section 2063.408 mandates that state agencies, as defined by Government Code Section 2054.003(13), must only enter or renew contracts to receive cloud computing services that comply with TX-RAMP requirements.
- TX-RAMP certification requirements apply to all contracts for cloud computing services entered into or renewed by a state agency, as defined by Government Code Section 2054.003(13).

Each independent cloud computing service must obtain a distinct certification that reflects the characteristics, functions, and security controls of the service. The scope of the TX-RAMP certification for a particular cloud computing service is confined to the system components within the boundaries of the individual solution.

TX-RAMP has three certification types:

- **Provisional Certification** is achieved only after the vendor's submission and TX-RAMP's approval of the TX-RAMP Acknowledgment and Inventory (A&I) Questionnaire. It is effective for 12 months from the date TX-RAMP grants the provisional certification. A cloud computing service may also achieve provisional certification after it receives an accepted status from Goram or FedRAMP (see Section 9.1 Certification Via Other RAMPs for additional information).
- **Level 1 Certification**, for low impact information resources, is achieved after vendor submission and TX-RAMP approval of the TX-RAMP A&I Questionnaire and the TX-RAMP Level 1 Assessment Questionnaire or by achieving the corresponding accepted GovRAMP[1] or FedRAMP authorization.
- **Level 2 Certification**, for moderate or high impact resources, is achieved after submission and TX-RAMP approval of TX-RAMP A&I Questionnaire and the TX-RAMP Level 2 Assessment Questionnaire or by achieving a corresponding accepted GovRAMP or FedRAMP authorization.

Provisional certification permits a state agency to contract for the use of a provisionally certified product for the length of the active provisional certification.

If at any point during the certification process, a cloud computing service achieves an accepted GovRAMP or FedRAMP status prior to the expiration of the provisional status, the cloud service provider must submit a change request form notifying TX-RAMP of the status change to receive a full reciprocal TX-RAMP certification. That TX-RAMP certification will remain valid as long as the cloud service maintains that reciprocal status as described in Section 9.1 Certification Via Other RAMPs.

4. Responsibilities

All responsibilities are set forth in Government Code Section 2063.408 and 1 Texas Administrative Code Chapter 202.

4.1 Agency Responsibilities

A state agency that is contracting with a vendor to receive cloud computing services must comply with Government Code Section 2063.408 statutory requirements and 1 Texas Administrative Code Chapter Section 202.5. These responsibilities include but are not limited to:

- Determining whether a contract with a vendor to provide cloud computing services is subject to TX-RAMP requirements.
- Determining what constitutes a cloud computing service.
- Ensuring that the state agency's contract terms and conditions require appropriate compliance with TX-RAMP.
- Determining the certification level required for a cloud computing service that the vendor is contracting with the agency to provide.

4.2 TX-RAMP Responsibilities

TX-RAMP administers the program, including creating and amending the administrative rules and the program manual as appropriate. TX-RAMP is responsible for:

- Assessing and certifying cloud computing services;
- Managing the Continuous Monitoring process; and
- Monitoring CSP compliance with TX-RAMP requirements.

4.3 Cloud Service Provider Responsibilities

Cloud Service Providers (CSPs) are responsible for:

- Providing all required assessment information and responding to TX-RAMP staff inquiries

promptly.

- Maintaining compliance with security control requirements and notifying the appropriate parties if the cloud computing service loses its certification.
- Adhering to all program compliance requirements included in this program manual.

5. Scope

5.1 Cloud Computing Services

Only cloud computing services, as defined by Government Code Section 2063.408(a), are subject to TX-RAMP certification requirements.
The **TX-RAMP Scoping Tool** presents a series of questions based on TX-RAMP requirements presented in this Program Manual and may be used by agencies and CSPs to determine the appropriate TX-RAMP certification level

According to Government Code Section 2157.007, a cloud computing service "has the meaning assigned by Special Publication 800-145 issued by the United States Department of Commerce National Institute of Standards and Technology, as the definition existed on January 1, 2015."

According to the NIST Special Publication 800-145, cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.

There are five characteristics that broadly describe the overall cloud computing model which, depending on the Service Model, draws the lines of responsibility between a cloud computing service provider and the cloud computing customer. Identification of the Service Model is key to qualifying as a cloud computing service under the model defined by NIST and the TX-RAMP program.

5.1.1 Essential Characteristics:

1. **On-Demand Self-Service:** A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed without requiring human interaction with each service provider.
2. **Broad Network Access:** Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms.
3. **Resource Pooling:** The provider's computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand.
4. **Rapid Elasticity:** Capabilities can be provisioned and released rapidly and, in some cases, automatically scale outward or inward commensurate with demand.
5. **Measured Service:** Cloud systems automatically control and optimize resource use by leveraging a metering capability at some level of abstraction appropriate to the type of service.

5.1.2 Service Models:

1. **Software-as-a-Service (SaaS):** The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email) or a program interface. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user-specific application configuration settings.
2. **Platform-as-a-Service (PaaS):** The capability provided to the consumer is to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages, libraries, services, and tools supported by the provider. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, or storage, but has control over the deployed applications and possibly configuration settings for the application-hosting environment.
3. **Infrastructure-as-a-Service (IaaS):** The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources where the consumer is able to deploy and run arbitrary software, which can include operating systems and applications. The consumer does not manage or control the underlying cloud infrastructure but has control over operating systems, storage, and deployed applications, and possibly limited control of select networking components (e.g., host firewalls).

5.1.3 Deployment Models:

1. **Private cloud:** The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.
2. **Community cloud:** The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.
3. **Public cloud:** The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.
4. **Hybrid cloud:** The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds).

A state agency is ultimately responsible for determining whether a product meets the statutory definition of a cloud computing service and should consult with the state agency's own information security personnel and legal counsel.[2]

6. Cloud Services Not Subject to TX-RAMP Certification

If a cloud computing service is not subject to TX-RAMP certification requirements, it must still comply with any required control baselines established by the Security Control Standards Catalog, all agency-specific security requirements, and any other applicable federal or statutory requirements.

6.1 Non-substantive Use of Confidential State-controlled Data

Certain cloud computing services may not require TX-RAMP certification due to the unique circumstances of the service. This could include a determination by a state agency that the service is a low impact information resource that does not process or store confidential state-controlled data other than as needed for login capability or that processes or stores a negligible quantity and/or quality of confidential data and is expected to have no adverse effect on organizational operations, organizational assets, or individuals A state agency is responsible for determining whether the quantity and/or quality of confidential data is negligible.

A state agency is responsible for: determining whether a cloud computing service is not subject to TX-RAMP certification, documenting the TX-RAMP scoping determination, and maintaining an internal record of cloud computing services that it has designated as not subject to TX-RAMP certification.

6.2 Custom Developed Applications

Cloud services that are specifically designed, developed, and commissioned by a state agency for a customized solution are not subject to TX-RAMP certification. This does not include commercial off-the-shelf software platforms that are simply configured specifically for agency purposes.

A state agency that contracts with a vendor for a customized cloud service solution is responsible for dictating the unique specifications and security requirements that must be fulfilled prior to the system becoming operational. Any such system must also comply with any statutory and regulatory requirements, including but not limited to any necessary security control standards required by a state agency or TX-RAMP. The responsibility for assessing and

[2] https://texasdir.surveymonkey.com/r/8XW6KSQ (agencies) and https://texasdir.surveymonkey.com/r/28CCRGJ (vendors)

securing the service in accordance with all applicable laws, regulations, and standards rests solely with the contracting agency. A state agency must ensure that proper security controls, assessments, and validations are conducted throughout the development and implementation phases, aligning with the unique nature and specific requirements of the custom-built solution. Agencies are responsible for ensuring that any component cloud services, such as infrastructure-as-a-service or platform-as-a-service, used in the deployment of the custom-developed application comply with those same requirements.

7. TX-RAMP Control Baselines

There are two baseline standards for cloud computing services subject to TX-RAMP:

- TX-RAMP Low Impact Baseline (TX-RAMP Level 1); and
- TX-RAMP Moderate or High Impact Baseline (TX-RAMP Level 2).

7.1 TX-RAMP Low Impact Baseline (TX-RAMP Level 1)

TX-RAMP Level 1 certification is required for cloud computing services categorized by a state agency as low-impact information resources.

Low Impact Information Resources: Information resources whose loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- Cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced;
- Result in minor damage to organizational assets;
- Result in minor financial loss; or
- Result in minor harm to individuals.

7.2 TX-RAMP Moderate or High Impact Baseline (TX-RAMP Level 2)

TX-RAMP Level 2 certification is required for cloud computing services categorized by a state agency as moderate or high impact information resources as defined by 1 Texas Administrative Code Section 202.1(30) and 202.1(18).

Moderate impact information resources: Information resources whose loss of confidentiality, integrity, or availability could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- Cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced;
- Result in significant damage to organizational assets;
- Result in significant financial loss; or
- Result in significant harm to individuals that does not involve loss of life or serious life-threatening injuries.

High impact information resources: Information resources whose loss of confidentiality, integrity, or availability could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- Cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions;
- Result in major damage to organizational assets;
- Result in major financial loss; or
- Result in severe or catastrophic harm to individuals involving loss of life or serious life-threatening injuries.

The security control criteria for the TX-RAMP impact baselines can be found in Appendix A – TX- RAMP Control Baselines.

8. Minimum Baseline Determination

A state agency is responsible for determining the required TX-RAMP certification level for a cloud computing service. A state agency shall apply the criteria in the questions below when analyzing which certification is appropriate for the use of a particular cloud product for a particular purpose. A state agency's analysis shall be the basis for the determination of the minimum TX-RAMP certification level.

It is at a state agency's discretion which agency-created and -implemented data classification categories (e.g., public, sensitive, confidential, regulated, etc.) are subject to the baselines below. The broad categories of "nonconfidential" and "confidential" can include regulated, confidential, sensitive, and public data, but a state agency must determine which baseline is most appropriate for a cloud computing service that processes information classified by the state agency subject to the data classification policy implemented by that state agency.

The **TX-RAMP Baseline Scoping Tool** may be used to assist agencies in determining the minimum required baseline. This tool presents a series of questions based on TX-RAMP requirements presented in this Program Manual and resulting recommendations for the appropriate baseline.

9. TX-RAMP Certification

TX-RAMP will determine whether a certification is granted based upon TX-RAMP's assessment of required documentation. This assessment entails TX-RAMP's review and approval of:

- The TX-RAMP A&I Questionnaire; and
- The TX-RAMP Assessment Questionnaire, including all required documentation submitted to TX-RAMP by the CSP; or a recent qualifying third-party assessment and associated Fast Track Controls.

9.1 TX-RAMP Certification Paths

TX-RAMP certification for any baseline level shall be achieved in one of three ways:

- **TX-RAMP-conducted Assessment:** A CSP submits assessment responses and documentation to DIR for review;
- **Certification via Other RAMP:** A CSP achieves the corresponding authorization of an approved risk and authorization management program at the appropriate impact level; or
- **TX-RAMP Fast Track Assessment:** A CSP submits a qualifying third-party assessment and Fast Track control responses to TX-RAMP for review.[3]

Based on the certification path above, a CSP may obtain one of two certifications:

- **TX-RAMP Level 1 Certification** may be conferred only after TX-RAMP reviews and approves provider assessment responses documenting that the cloud computing service aligns with the security standards for Level 1 as specified in Appendix A – TX-RAMP Control Baselines or upon achieving a corresponding equivalency through an external RAMP.
- **TX-RAMP Level 2 Certification** may be conferred only after TX-RAMP reviews and approves provider assessment responses documenting that the cloud computing service aligns with the security standards for Level 2 as specified in Appendix A – TX-RAMP Control Baselines or upon achieving a corresponding equivalency through an external RAMP program.

9.2 Certification Via Other RAMPs

CSPs that receive a designation on the FedRAMP marketplace[4] or GovRAMP authorized products list[5] may inherit a corresponding status within TX-RAMP by submitting a request for a reciprocal TX-RAMP certification. The TX-RAMP certification will remain valid if the cloud service maintains the appropriate status with the external RAMP (FedRAMP or GovRAMP). If a CSP loses its external RAMP status, then it must comply with this Program Manual's requirements to ensure continued certification.

[3] A "qualifying third-party assessment" is defined in Section 15.3 - Accepted Fast Track Documentation.
[4] https://marketplace.fedramp.gov/products
[5] https://govramp.org/product-list/

TX-RAMP does not have a Low-impact SaaS equivalent. Cloud computing services authorized with Low-impact SaaS will not inherit a TX-RAMP certification.

Certification via GovRAMP[6]

GovRAMP Core – The GovRAMP Core security status demonstrates achievement of baseline NIST 800-53 Rev. 5 controls and documentation requirements as assessed and validated by the GovRAMP Program Management Office (PMO). The GovRAMP PMO will evaluate evidence submitted by the provider to satisfy the criteria for the cloud product's achievement of a GovRAMP Core security status. To maintain a GovRAMP Core security status, the provider must comply with quarterly Continuous Monitoring requirements that include submission of evidence of Core requirement compliance as requested by the GovRAMP PMO. Given the independent review and Continuous Monitoring requirements, cloud computing services that have a GovRAMP Core status will be granted a TX-RAMP Level 2 certification.

GovRAMP Ready – GovRAMP Ready status indicates that a cloud computing service has been assessed against the mandatory controls, approved by the GovRAMP PMO, and entered the Continuous Monitoring phase. Given the independent review and Continuous Monitoring requirements, cloud computing services that have a GovRAMP Ready status will be granted TX-RAMP Level 2 certification.

GovRAMP Provisionally Authorized – GovRAMP Provisional status indicates that the cloud service progressing through the GovRAMP authorization process has met the mandatory minimum requirements, submitted a security package for authorization consideration and is found to meet most but not all security requirements. Providers with a GovRAMP Provisional status comply with Continuous Monitoring requirements and submit further documentation to obtain authorization. Given the high degree of alignment between TX-RAMP security controls and the GovRAMP Provisional designation, combined with the Continuous Monitoring requirements, cloud computing services that have GovRAMP Provisionally Authorized status will be granted TX-RAMP Level 2 certification.

GovRAMP Authorized – Cloud computing services that have a GovRAMP Authorization will be granted TX-RAMP Level 2 certification.

GovRAMP Other Statuses – Other GovRAMP designations not specifically called out above may be eligible for TX-RAMP Provisional certification; however, TX-RAMP will *not consider* GovRAMP Snapshot as a long-term certification solution. A GovRAMP Snapshot is a one-time gap assessment of the cloud service against the GovRAMP standards. A single GovRAMP Snapshot may be used to obtain TX-RAMP Provisional certification, but the 18-month time restriction will still apply. Cloud services that enroll in the GovRAMP Progressing Snapshot program will receive TX-RAMP Provisional certification for the length of enrollment within the progressing snapshot program.

[6] Wherever the term "GovRAMP" is used, it shall be understood to implicitly include "StateRAMP."

Certification via FedRAMP

FedRAMP Authorized – Cloud computing services that receive a FedRAMP Authorization will be granted the corresponding TX-RAMP certification Level (Low Impact for TX-RAMP Level 1, Moderate or High Impact for TX-RAMP Level 2).
FedRAMP In Process – Cloud computing services that receive a FedRAMP In Process designation will be granted TX-RAMP Provisional certification. Once the cloud service receives authorization, then the corresponding TX-RAMP certification Level will be granted.
FedRAMP Ready – Cloud computing services that receive a FedRAMP Ready designation will be granted TX-RAMP Provisional certification. Once the cloud service receives authorization, then the corresponding TX-RAMP certification Level will be granted.

10. TX-RAMP Provisional Certification

A valid TX-RAMP Provisional certification permits agencies to enter or renew a contract for cloud computing services subject to TX-RAMP requirements prior to the service receiving a full TX-RAMP certification. TX-RAMP Provisional certification is effective for 12 months from the date that the provisional certification is granted by TX-RAMP.

TX-RAMP Provisional certification is achieved by completing the TX-RAMP A&I Questionnaire. To initiate the questionnaire, a CSP must complete the TX-RAMP Request Form as described in Section 11 Assessment Process – Level 1 and Level 2.

10.1 Provisional Certification Considerations

TX-RAMP Provisional certification does not indicate compliance with TX-RAMP security baseline standards of a cloud computing service. State agencies should carefully evaluate their business needs and organizational risk considerations when selecting a provisionally certified cloud computing service.

10.2 Failure to Attain Full Certification before Provisional Status Expiration

Failure to attain TX-RAMP Level 1 or Level 2 certification prior to the expiration of the provisional certification will result in a lapse in certification. During this lapse, the cloud computing service will not be TX-RAMP-certified and, as such, will be noncompliant with TX-RAMP requirements unless the obligations stated in Section 13 Transitional Grace Period have been met.

10.3 TX-RAMP Provisional Certification via Other RAMP

TX-RAMP Provisional certification may be granted for a cloud computing service that has achieved a FedRAMP or GovRAMP status other than authorized that indicates progress toward achieving FedRAMP or GovRAMP authorization.

TX-RAMP Provisional certifications achieved via FedRAMP or GovRAMP are dependent upon the status of the cloud computing service under the respective program rather than the 18-month provisional period.

11. Assessment Process - Level 1 and Level 2

The following steps outline the typical workflow of progressing through the TX-RAMP process. TX-RAMP's review may differ slightly depending upon variables such as whether the certification process began under a prior version of the TX-RAMP Program Manual. Refer to *Figure 1: TX-RAMP High Level Process* for a graphical representation of the TX-RAMP high-level process.

1. **Initial Request**
    - CSPs seeking certification of a cloud computing service must first complete the TX-RAMP Assessment Request form (request form) through the TX-RAMP webpage. The request form should be completed by the actual developer of the cloud service. SaaS providers should include their company as the manufacturer/developer, not the underlying IaaS provider.
    - The vendor submitting the CSP assessment request must create an account to gain access to the TX-RAMP Assessment Request form.
    - TX-RAMP staff review and process the form.

2. **Engagement Record Creation**
    - Once the request information is vetted and approved, an engagement record is created.
    - The engagement record serves as the central repository for information about the cloud service.

3. **Acknowledgement and Inventory Form**
    - TX-RAMP launches the A&I Form to the CSP contact(s) via the Engage platform.
    - CSP contact(s) complete and submit the form back to TX-RAMP.
    - TX-RAMP staff review the submitted form and either approve it or request additional information.

4. **Provisional Certification**
    - Once the A&I Form is approved, TX-RAMP may grant provisional certification.

5. **TX-RAMP Assessment Questionnaire**
    - After provisional certification is conferred, TX-RAMP launches the TX-RAMP assessment questionnaire to the contact(s) on file.
    - The date the assessment questionnaire is launched may vary depending on the requested assessment initiation date.
    - The CSP completes the assessment questionnaire, including the TX-RAMP Security Plan (Control Implementation Workbook) and submits it to TX-RAMP.

6. **Assessment Review**
    - The assessment goes into a queue. TX-RAMP will review assessments in the order that they are received.
    - TX-RAMP will not review incomplete submissions, including submissions that do not include all required information or provide incomplete documentation.

- TX-RAMP will review the submitted information to determine whether certification may be granted.

7. **Certification Approval**
   - TX-RAMP determines whether the certification is approved.
   - Once approved, TX-RAMP updates the records and notifies the CSP contact(s) of the decision.

8. **Continuous Monitoring**
   After certification is granted, the CSP enters the Continuous Monitoring period and is responsible for adhering to Continuous Monitoring requirements as outlined in Section 17 Continuous Monitoring.

9. **Recertification**
   - TX-RAMP sends recertification notifications to the listed CSP contact(s) prior to the expiration of a certification.
   - The CSP may initiate the recertification process up to 12 months prior to the expiration of the certification.

DIR reserves the right to review and approve or deny any request for TX-RAMP assessment of a given cloud computing service. DIR oversees the assessment process, which ensures that assessment resources are utilized judiciously and align with the broader cybersecurity objectives and regulations of the state of Texas.

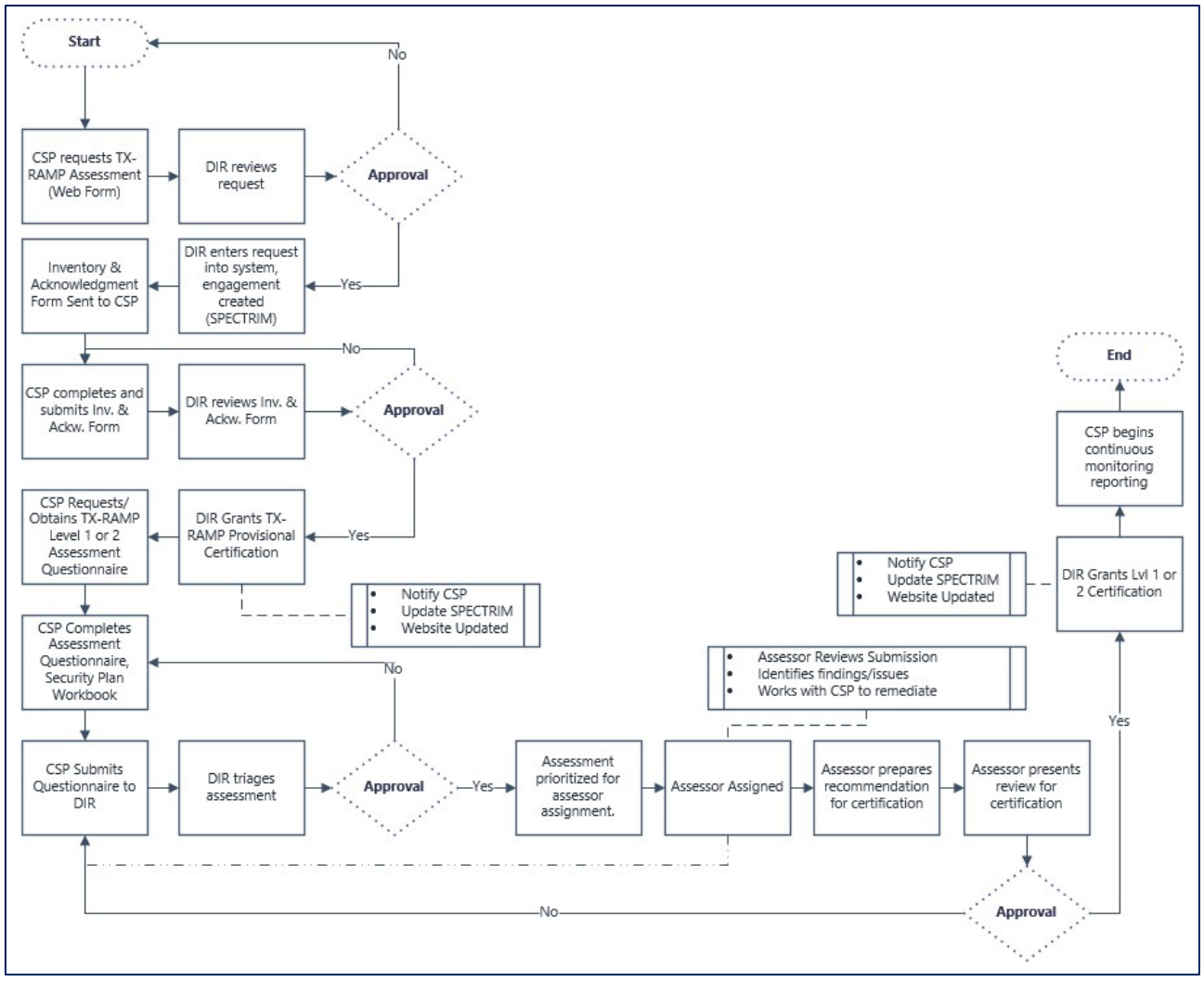


Figure 1: TX-RAMP High Level Process

12. Certification Extensions

12.1 TX-RAMP Provisional Certification Extensions

CSPs may not apply for a new provisional certification for a cloud computing service that was previously granted a provisional certification and failed to achieve a Level 1 or Level 2 certification.

However, at TX-RAMP's discretion, a cloud computing service's provisional status may be extended for six months if the service has not received full TX-RAMP certification after the initial 12-month provisional certification.

If, at the expiration of the six-month extension, the provider has not yet received approval of their TX-RAMP certification, then DIR may grant an additional six-month extension if:

- The initial 12-month provisional certification and six-month extension have expired;
- The provider has begun the process to receive full TX-RAMP certification; and
- TX-RAMP has not completed the approval process.

It is at TX-RAMP's discretion to approve an additional three-month extension. TX-RAMP may consider provisional certification extension requests submitted by CSPs who do not meet the above criteria on a case-by-case basis.

12.2 TX-RAMP Provisional Certification Extension Request Process

The extension process is designed to provide CSPs with the opportunity to maintain their certification status while they complete necessary assessments or while TX-RAMP completes its review. It is important for CSPs to submit their change request forms in a timely manner and to provide all necessary information to facilitate the review process.

- **Extension Request Submission:** The CSP submits the change request form. This form should be filled out with all the necessary details and submitted before the expiration of the current provisional certification.
- **Form Review and Processing**: Upon receiving the change request form, TX-RAMP reviews the form. This involves checking the details provided in the form and assessing the reasons for the extension request.
- **Provisional Certification Extension:** If the review process is successful, TX-RAMP may grant a provisional certification extension. The extension period can be up to 6 months, depending on the circumstances.

12.3 Extension while under TX-RAMP assessment review

In certain situations, TX-RAMP will apply an extension of a CSP's provisional certification. This occurs when:

- The CSP has submitted their assessment for review,

- TX-RAMP has not completed the review of the submitted assessment; and
- The expiration date of the current provisional certification is at minimum six months away.

In such a case, TX-RAMP will apply six-month extension to the provisional certification. This ensures that the CSP maintains their certification status while TX-RAMP completes the review process.

12.4 Level 1 and Level 2 Certification Extensions

Cloud computing services with an active but expiring Level 1 or 2 certification may apply for an extension of their active TX-RAMP certification using the change request form. Level 1 or 2 certification extensions may be granted after TX-RAMP review and approval, not to exceed six months. TX-RAMP reserves the right to grant additional extensions on a case-by-case basis.

13. Transitional Grace Period

13.1 Purpose

The **Transitional Grace Period** is established to enable agencies to plan and execute an orderly transition from a non-compliant solution to a compliant solution if a certification lapses or is revoked. This approach recognizes the complexities involved in migrating to a new solution and allows for flexibility to ensure continuity of operations.

13.2 Agency Responsibilities

State agencies will remain in compliance with TX-RAMP requirements throughout the Transitional Grace Period if the transition plans meet the specified criteria and are executed in accordance with their documented timelines. Any deviations from or exceptions to the stated timeline must be communicated to TX-RAMP.

Agencies are responsible for developing, documenting, and adhering to a transition plan that meets the minimum criteria specified below. A state agency must retain this documentation and ensure that all actions are taken in accordance with the plan's timelines.

While agencies are not required to submit the complete transition plan to TX-RAMP for review and approval, state agencies must adhere to the below-established criteria to demonstrate compliance with TX-RAMP requirements during the Transitional Grace Period and must notify TX-RAMP of their intent to leverage the Transitional Grace Period in compliance with Section 14.5 Reporting by emailing TX-RAMP@dir.texas.gov.

Reporting agencies that leverage the Transitional Grace Period option must report the use of applicable services and their anticipated timeline for transition to TX-RAMP on a biennial basis by emailing TX-RAMP@dir.texas.gov.

13.3 Minimum Criteria for the Transition Plan

- **Identification of Affected Services:** Clearly list and describe the services affected by the lapse or revocation of certification.
- **Timeline for Transition:** Provide a realistic and achievable timeline for the migration to a compliant solution, including key milestones and deadlines. The timeline for transition may not exceed 24 months from planned inception to execution.
- **Risk Assessment:** Conduct a risk assessment to identify and mitigate potential security and operational risks during the transition.
- **Selection of Compliant Solution:** Detail the process for selecting a TX-RAMP-compliant solution that meets a state agency's needs.
- **Migration Strategy:** Outline the methods and procedures for migrating data and operations to the new solution, ensuring data integrity and availability.

- **Monitoring and Reporting:** Establish ongoing monitoring and internal reporting mechanisms to track progress and address any challenges or delays promptly.
- **Contingency Planning:** Include contingency measures to address unexpected issues or delays, ensuring uninterrupted service delivery.

14. TX-RAMP Assessment Components

14.1 TX-RAMP Acknowledgment and Inventory Questionnaire

The TX-RAMP A&I Questionnaire must be completed by all CSPs and consists of the following components:

- CSP Acknowledgment of Texas Security Requirements; and
- Information Security Documentation Inventory.

Failure to submit the A&I Questionnaire will remove your CSP from the approved products listing.

Cloud Service Provider Acknowledgment of Texas Security Requirements

The acknowledgment form asks the CSP to acknowledge that:

- Their company is or may be required to comply with certain statutory, rule, or contractual security requirements;
- They must provide an information security point of contact and a process for requesting security documentation or artifacts listed in the TX-RAMP Information Security Documentation Inventory, both of which may be shared with state agencies as authorized by the CSP; and
- They authorize DIR to share the CSP Acknowledgment and TX-RAMP Information Security Documentation Inventory with state agencies.

Information Security Documentation Inventory

The TX-RAMP Information Security Documentation Inventory (ISDI) asks the CSP to confirm the security documentation, questionnaires, certifications, or other designations that are available and relevant to the cloud computing service. The ISDI identifies the security documentation, questionnaires, certifications, or other designations that the CSP will make available to a state agency upon request.

CSPs must identify an information security point of contact and instructions on how a state agency may request documentation. The provider must submit any changes to the inventory or contact information as soon as reasonably possible.

14.2 TX-RAMP Assessment Questionnaire

The TX-RAMP Assessment Questionnaire (questionnaire) is the mechanism by which assessment responses and required documentation are collected from a CSP. The questionnaire contains multiple choice, narrative, and file attachment questions to obtain information about the security posture of the cloud computing service. The questionnaire is a web-based information collection function of SPECTRIM.
The TX-RAMP assessment questionnaire is a critical component of the certification

process, demanding careful and comprehensive completion. It consists of several key elements, each of which must be fully addressed for consideration. The assessment questionnaire consists of general questions about the system, company, and functionality as well as file upload attachments for the boundary and data flow diagrams to visually represent the architecture and operation of the service.

The assessment questionnaire also requires the CSPs to submit a completed TX-RAMP Security Plan Workbook. The TX-RAMP Security Plan Workbook asks the CSP to describe the implementation status, details, and other relevant information related to each baseline control requirement. CSPs should ensure that a sufficient level of detail is provided in the TX-RAMP Security Plan Workbook, fully outlining how each requirement is met. It's important to note that control family policies and procedures are not required to be submitted as part of the assessment questionnaire itself; however, they may be requested as evidentiary artifacts during the assessment process. All components of the assessment must be fully completed, and any omission or inadequacy may result in the application being deemed incomplete, potentially affecting eligibility for certification. This template will be made available on the TX-RAMP webpage.

14.3 TX-RAMP Security Plan Workbook Best Practices

When completing the control implementation descriptions required for assessment submission, there are several best practices that can help CSPs ensure accuracy, clarity, and compliance with the requirements.

- **Understand the Requirements:** Thoroughly review the specific control requirements, guidelines, and expectations. Understanding the underlying principles helps in providing precise and relevant information.
- **Be Detailed and Specific:** Offer clear, concise, and specific descriptions of how each control is implemented. Avoid vague or generic statements that could lead to ambiguity.
- **Use Standardized Terminology:** Where possible, use industry-standard terminology and definitions. This ensures consistency and aids those reviewing the document in understanding the implementation.
- **Provide Evidence and Examples:** Where applicable, include evidence or examples that demonstrate the implementation of the control. This could include references to specific policies, procedures, or technical configurations.
- **Align with Organizational Practices:** Ensure that the descriptions accurately reflect the actual practices within the organization. Misalignment between description and practice can lead to non-compliance findings.
- **Avoid Unnecessary Jargon:** While using standardized terminology is encouraged, avoid overly technical jargon that may not be understood by all readers. Keep the language accessible to a broader audience without losing precision.
- **Maintain Consistency:** If there are multiple people working on the

description, ensure that there is consistency in style, tone, and content across the document. Consider using templates or guidelines to achieve this.

- **Review and Validate:** Have the description reviewed by subject matter experts within the organization, such as security professionals, legal advisors, or IT operations staff. This helps in identifying any gaps or inaccuracies.
- **Prepare for Verification**: Be ready to provide further evidence or clarification if requested during an assessment process. This includes having access to supporting documentation, policies, or artifacts.

- **Document Exceptions and Justifications:** If there are deviations or exceptions to standard control implementations, provide a clear justification and explain how the associated risks are mitigated.

By adhering to these best practices, an organization can create a robust and clear control implementation description that not only meets the requirements of a specific framework like TX-RAMP but also provides a valuable internal reference for managing and maintaining the relevant controls.

14.4 Plan of Action and Milestones (POA&M)

CSPs are required to develop a Plan of Action and Milestones (POA&M) for each security control identified as deficient (i.e. not implemented, partially implemented). TX-RAMP requires POA&Ms exclusively for control deficiencies rather than individual vulnerabilities as part of the assessment process.

The POA&M serves to bridge the gap between the services' current state and the TX-RAMP required state, facilitating a better understanding of how these control deficiencies will be addressed. The CSP must generate or otherwise provide a POA&M for each control deficiency and submit these with the TX-RAMP assessment questionnaire. TX-RAMP will review POA&Ms during the assessment phase and determine whether the proposed solution sufficiently addresses the failed control.

POA&Ms should be revisited by the CSP on at least a quarterly basis. Once a CSP fully implements a POA&M, the CSP must report the closure of the POA&M to TX-RAMP through the next regularly scheduled Continuous Monitoring report.

15. TX-RAMP Fast Track Assessment

15.1 TX-RAMP Fast Track Assessment Overview

The TX-RAMP Fast Track Assessment is a streamlined process designed to expedite the certification of cloud products by allowing CSPs to leverage existing TX-RAMP-approved third-party assessments or audit reports to provide verified evidence of security practices.

A cloud product that qualifies for a Fast Track assessment is not guaranteed a TX-RAMP certification; qualifying for the Fast Track assessment simply allows the CSP to provide potentially reduced documentation based upon TX-RAMP's review and acceptance of the certification, assessment, or audit report

As a reminder, DIR cannot enter into any form of nondisclosure agreements with CSPs for any components of the TX-RAMP process, including the review of third-party assessment or audit reports required to leverage the Fast Track certification route.

15.2 Third-party Assessment Acceptance Criteria

A CSP may submit third-party assessments or audit documents described by Section 15.3 Accepted Fast Track Documentation to TX-RAMP for consideration in determining whether the service qualifies for the Fast Track assessment process. This must be done in compliance with the procedures outlined by this section.

TX-RAMP reserves the right to accept or reject third-party assessments or audit documents when determining whether a cloud service is eligible for the Fast Track TX-RAMP Assessment process. While these external evaluations can potentially expedite TX-RAMP's assessment process, TX-RAMP is not obligated to accept these external evaluations. TX-RAMP maintains full discretion in its decision-making process, ensuring that all certifications meet the stringent standards set by TX-RAMP.

To be considered for a Fast Track assessment, a CSP's documentation must be an assessment or audit listed by Section 15.3 Accepted Fast Track Documentation that has been conducted within the previous 24 months. This ensures that the evaluation accurately reflects the security posture of the service in question.

15.3 Accepted Fast Track Documentation

TX-RAMP accepts the below third-party assessments or audit reports to be considered for Fast Track assessment:

- SOC 2 Type 2;
- HITRUST Authorized External Assessor Validated Assessment;
- PCI DSS Qualified Security Assessor Audit Report on Compliance;
- ISO 27001;
- ISO 27017;
- ISO 27018;
- CSA STAR II;
- FISMA; and
- Any third-party assessment or audit artifacts authorized by TX-RAMP and posted as part of the comprehensive list on the TX-RAMP webpage, as described below.

At its discretion, TX-RAMP may evaluate and determine that additional third-party assessment or audit artifacts are acceptable for the TX-RAMP Fast Track assessment process. TX-RAMP will publish any additional acceptable third-party assessment or audit reports on the TX-RAMP webpage.

A third-party assessment or audit artifact that is not included in the above list or identified by the comprehensive list posted to the TX-RAMP webpage cannot be used for the Fast Track assessment process.

Third-party certification, assessment, or audit reports must be relevant to the cloud service seeking the Fast Track option. Security artifacts related to the underlying IaaS of a SaaS do not qualify for the TX-RAMP Fast Track assessment process.

15.4 TX-RAMP Level 1 Fast Track Assessment

At TX-RAMP's discretion, a CSP seeking Level 1 certification may qualify for assessment by the Fast Track process based on the results of an independent third-party certification, assessment, or audit report and TX-RAMP will complete a review of the required Level 1 TX-RAMP security controls. TX-RAMP may require additional information as needed to determine whether certification can be granted.

15.5 TX-RAMP Level 2 Fast Track Assessment

At TX-RAMP's discretion, a CSP seeking Level 2 certification may qualify for assessment by the Fast Track process based on the results of an independent third-party certification, assessment, or audit report, and TX-RAMP will complete a review of the required Level 2 security controls.

DIR may require additional information as needed to determine whether certification can be granted.

15.6 Fast Track Request Process

CSPs seeking the Fast Track process for a cloud service must complete the TX- RAMP Fast Track Request Form. CSPs currently undergoing a TX-RAMP assessment may elect to switch to the Fast Track process. Once the initial request is processed and approved, TX-RAMP will launch a questionnaire to collect the third-party assessment or audit report.
TX-RAMP will review the artifacts and determine whether the service qualifies for the Fast Track process. If the service qualifies, then TX-RAMP will launch a subsequent Fast Track questionnaire to the CSP.

15.7 Fast Track Continuous Monitoring

CSPs that receive TX-RAMP certification through the Fast Track process are subject to the same Continuous Monitoring requirements as the services that obtain certification by the standard assessment process as detailed in Section 17 Continuous Monitoring.

16. Assessment Considerations

16.1 Time Required to Complete Assessment Review

The length of TX-RAMP's assessment of a certification request depends on several factors including but not limited to:

- Completeness of CSP documentation and responses;
- TX-RAMP assessment level; and
- CSP responsiveness to TX-RAMP outreach.

CSPs are expected to respond to TX-RAMP requests for clarification or additional evidence of compliance within 10 business days. Failure to respond to requests for clarification in a timely manner may result in rejection of the assessment and may require resubmission and reprioritization.

TX-RAMP is not responsible for delays in a state agency's procurement because of a CSPs lack of responsiveness.

16.2 SaaS and Subservice Cloud Providers

SaaS applications operating on a cloud infrastructure/platform (IaaS/PaaS) product do not inherit the underlying TX-RAMP certification from the cloud infrastructure provider. Separate certifications are required for SaaS products that leverage certified cloud infrastructure products. The SaaS product may, however, inherit applicable controls from the certified infrastructure.

The SaaS CSP is responsible for providing evidence of compliance with required controls and documentation related to the non-inheritable controls to achieve TX-RAMP certification.

Significant changes, as described in Section 17.4 Significant Change Reporting, in the infrastructure of the SaaS solution must be reported to TX-RAMP.

16.3 Cloud Reseller Functions

Primary contracting CSP's, including CSPs who resell cloud computing services, shall specifically identify which of the products provided are or include cloud computing services, as defined by Government Code Section 2157.007, and ensure that they have a point of contact for the vendor providing cloud computing services. A reseller shall coordinate assessment responses with cloud computing service vendors. If a CSP is already certified, the reseller shall require the cloud computing service's vendor to provide documented evidence of the service's TX-RAMP certification to them for ready provision to DIR and any state agency contracting with the reseller for the cloud computing service.

17. Continuous Monitoring

17.1 Overview

Continuous Monitoring programs facilitate ongoing awareness of threats and vulnerabilities affecting a cloud service and could potentially risk the security of state data

TX-RAMP established the Continuous Monitoring criteria below for CSPs contracting with state agencies for cloud computing services. State agencies may require additional Continuous Monitoring activities directly through contractual agreements.

Should a state agency identify significant concerns related to the security posture of a certified cloud computing service, the agency may notify TX-RAMP of the identified concern. TX-RAMP will provide any assistance to state agencies in resolving the collection of the necessary documentation and, if appropriate, may revoke the cloud computing service's TX-RAMP certification due to the provider's failure to provide accurate or timely documentation as described below.

If a CSP has been TX-RAMP certified through the FedRAMP or GovRAMP equivalent acceptance process, then the CSP will not be required to provide Continuous Monitoring artifacts to TX-RAMP. State agencies contracting with a CSP who has attained a reciprocal TX-RAMP certification by another RAMP should consider the addition of rigorous, additional contractual provisions requiring continuous FedRAMP or StateRAMP (as appropriate) acceptable status and notification requirements if such certification is revoked or otherwise removed.

17.2 Vulnerability Reporting

TX-RAMP established the following minimum Continuous Monitoring requirements to ensure that CSPs comply with TX-RAMP. Any additional Continuous Monitoring requirements are at the discretion of the contracting state agency.

For TX-RAMP Level 2-certified cloud computing services, CSPs must provide quarterly vulnerability reports of identified vulnerabilities and mitigation activities to TX-RAMP through SPECTRIM.

For TX-RAMP Level 1-certified cloud computing services, CSPs must provide annual vulnerability reports of identified vulnerabilities and mitigation activities to TX-RAMP through SPECTRIM.

Vulnerability reporting for a given cloud service should be related to the assets used in the delivery of the certified service to include application, database, and infrastructure vulnerabilities where applicable. TX-RAMP will not review vulnerabilities unrelated to the certified cloud computing service.

Vulnerability severity categorization is based on the NIST National Vulnerability Database Common Vulnerability Scoring System (most current version).[7]

As part of the vulnerability reporting, CSPs must report identified vulnerabilities with the vulnerability severity category along with:

- A description of remediation plans; or
- Mitigation activities associated with high and critical-severity vulnerabilities if the CSP is not remediating the vulnerability.

CSPs shall submit vulnerability reporting documentation through SPECTRIM. SPECTRIM will provide notice to the designated CSP point of contact to complete the Continuous Monitoring questionnaires at the required interval. Once submitted, TX-RAMP will log the associated vulnerability report information to the TX-RAMP-certified cloud computing service in SPECTRIM and make it available to state agencies who have indicated that they are contracting for that cloud computing service.

State agencies are responsible for developing a risk-based approach to the review of relevant TX-RAMP Continuous Monitoring reports. TX-RAMP may require greater frequency of Continuous Monitoring activities or revoke a CSP's TX-RAMP certification if the CSP does not remediate or adequately address identified vulnerabilities through compensating controls within the prescribed timelines.

TX-RAMP reserves the right to intervene and conduct an impromptu request for evidence regarding vulnerability management practices.

[7] NIST National Vulnerability Database: https://nvd.nist.gov/vuln-metrics/cvss

Table 1: Vulnerability Severity Reporting Requirements

CVSS Severity	Reporting Components
Low (0.1-3.9)	•Number Identified During Reporting Period •Number Remediated During Reporting Period •Number of Existing Vulnerabilities
Medium (4.0-6.9)	•Number Identified During Reporting Period •Number Remediated During Reporting Period •Number of Existing Vulnerabilities
High (7.0-8.9)	•Number Identified During Reporting Period •Number Remediated During Reporting Period •Number of Existing Vulnerabilities •Planned/Current Remediation •Activities/Mitigating/Compensating Controls
Critical (9.0-10.0)	•Number Identified During Reporting Period •Number Remediated During Reporting Period •Number of Existing Vulnerabilities •Planned/Current Remediation •Activities/Mitigating/Compensating Controls

17.3 Reporting Breach of System Security

A CSP whose cloud computing service is certified by TX-RAMP shall disclose any breach of system security of the certified cloud offering in compliance with Texas Business & Commerce Code Section 521.053. A CSP whose TX-RAMP certified service has experienced a breach of system security shall notify TX-RAMP within 48 hours of becoming aware of the breach of system security. A breach of system security notifications must be sent by authorized company officials to TX-RAMP@dir.texas.gov with a description of the incident, potentially impacted Texas customers, and any additional relevant information.

A CSP must report a suspected or confirmed breach to appropriate parties as required by law. If the suspected or confirmed breach involves the unauthorized disclosure of 250 or more Texans, the CSP must also report the breach to the Office of the Attorney General of Texas as required by law.

17.4 Significant Change Reporting

After a CSP obtains a TX-RAMP certification for its cloud computing service , the next phase is the Continuous Monitoring of the system security controls. Continuous Monitoring includes documenting changes to the cloud computing service or environment of operation, conducting security impact analyses of the associated changes, and reporting the security state of the system to TX-RAMP as directed in this TX-RAMP Program Manual.

A CSP may occasionally need to make changes to their cloud computing services. TX-RAMP may consider certain changes "significant." A significant change is one that is likely to negatively and substantively affect the security state of the information system. Non-significant changes would typically be addressed by the CSP Configuration Management Plan. Significant changes, however, are those outside of typical change management, the scope of which would call the initial assessment judgement into question.

Significant changes to a system that may trigger an event-driven authorization action may include, but are not limited to:

a. Modifications to system ports, protocols, or services;
b. Installation of a new or upgraded hardware platform;
c. Modifications to how information, including PII, is processed;
d. Modifications to cryptographic modules or services;
e. Changes in information types processed, stored, or transmitted by the system; or
f. Modifications to security and privacy controls.

TX-RAMP complies with NIST standards and guidance. With respect to significant changes, it follows NIST Special Publication (SP) 800-37 and NIST SP 800-137.

A CSP must report significant changes to a certified product or service to TX-RAMP within 30 days of the date that the change is made. A CSP may also report a significant change to a product or service to state agencies with whom they contract; this would not, however, meet the requirement to report significant changes to TX-RAMP.

The CSP must use the TX-RAMP Significant Change Form to inform TX-RAMP of any significant change to their product or service.

TX-RAMP is responsible for completing a certification review based on information included in the Significant Change Report. TX-RAMP will determine whether reported changes qualify as significant changes and whether the change warrants a review of the certification status including further assessment of security controls. TX-RAMP may set the certification status as provisional during further controls assessment.

18. Dispute Resolution

18.1 Appeals Process

Request for Appeal to the State of Texas Chief Information Security Officer

CSPs or primary contractors/resellers acting on behalf of a CSP may appeal a TX-RAMP certification decision directly impacting their cloud computing service by emailing a written request for appeal containing any information pertinent to the issue to TX-RAMP@dir.texas.gov. A CSP may not appeal the certification decision of another service provider's product. The State of Texas Chief Information Security Officer shall review the request for appeal and any necessary documents before issuing a determination either upholding or overturning the initial decision regarding the cloud computing service's certification decision.

Final Request for Appeal to the DIR Executive Director

If the State of Texas Chief Information Security Officer has issued a determination with which a CSP disagrees, the CSP may submit a final request for appeal in writing addressed to DIR's Executive Director at TX-RAMP@dir.texas.gov. This step may only be taken if the CSP has submitted a request for appeal to the State of Texas Chief Information Security Officer and they have already issued a determination regarding the request for appeal. Upon receipt of the final request for appeal, the Executive Director shall review the final request for appeal and any necessary documents before issuing a final determination.

18.2 Grievance Process

A state agency may file a grievance or complaint against a TX-RAMP-certified CSP if the state agency obtains credible information that a CSP has deviated from the requirements of TX-RAMP by emailing TX-RAMP@dir.texas.gov.

TX-RAMP will evaluate grievances to determine whether corrective action or revocation of certification status are warranted.

19. Certification Revocation

TX-RAMP reserves the right to revoke TX-RAMP certification status at its discretion. Failure of a CSP to maintain baseline compliance with TX-RAMP requirements described by this Program Manual will result in revocation of a product's TX-RAMP certification. Events that will result in a revocation include but are not limited to the following:

- Failure to inform required parties in a timely manner of significant changes to the cloud computing service;
- Failure to inform required parties of the loss of other accepted risk and authorization management program (e.g. FedRAMP, GovRAMP) certification;
- Failure to provide required Continuous Monitoring documents;
- A report of false or misleading information to TX-RAMP or a state agency;
- Referencing non-certified cloud computing services as TX-RAMP certified; and
- Failure to report a breach of system security to TX-RAMP within 48 hours of discovery.

The loss of a cloud computing service certification by another RAMP will result in the revocation of the service's TX-RAMP reciprocal certification. TX-RAMP shall review the circumstances of any reported violation of TX-RAMP to determine if a product's TX-RAMP certification shall be revoked.

20. Recertification

TX-RAMP Level 1 and Level 2 certifications are valid for three years from the date the certification was conferred upon a cloud computing service, provided that the CSP is compliant with program requirements enumerated in this Program Manual. TX-RAMP will review all required documentation for recertification and, if approved, a new TX-RAMP certificate will be issued with an expiration date 3 years from the previous expiration date, regardless of when the recertification process is complete.

If the CSP takes no action to recertify by the expiration date, the TX-RAMP certification will expire, and TX-RAMP will remove the cloud computing service from the certified products list.

20.1 Recertification Process

The identified points of contact for TX-RAMP certified cloud computing services will be notified by automated email 12 months prior to the certification's expiration date. An additional notification will be sent 90 days prior to the certification's expiration date. This notification will include instructions for completing the recertification process. A request to initiate the recertification process may be made by the CSP beginning 12 months prior to the certification's expiration date.
Recertification requires the CSP to submit a recertification A&I form, followed by an assessment of the relevant controls based on certification level. Level 1 certifications require a

review of the submitted information for cloud service compliance with the 38 control requirements and Level 2 includes a review for 48 control requirements. The information provided by the vendor must confirm the continuance and accuracy, completeness, and compliance of security standards required by CSPs providing services to State of Texas agencies.

Once the recertification is qualified and approved, TX-RAMP will update the system record and send a certificate with an updated expiration date.

21. Program Certification Change Management

21.1 Cloud Service Provider Control Changes Compliance Timeline

As TX-RAMP evolves, it may adopt or modify security control requirements to stay aligned with prevailing standards and threats. CSPs are expected to remain responsive to these changes and adhere to any updated requirements promptly. For control changes that go beyond administrative or superficial adjustments, CSPs must implement the new or revised controls no later than 18 months from the date the changes are formally adopted by the program. It is incumbent upon CSPs to develop a systematic and well-articulated plan to meet these new or revised control requirements within the prescribed timeline. This plan should encompass a clear understanding of the changes, an implementation strategy, and necessary resources allocation. If a CSP anticipates any challenges in satisfying the controls within the specified timeframe, it must timely communicate these concerns to TX-RAMP.

22. Document Version History

Version	Date	Comments
1.0	October 28, 2021	Initial Publication
2.0	October 20, 2022	1st Major Revision: • Control Alignment with NIST 800-53 Revision 5 • Added TX-RAMP Acknowledgement and Inventory • Extension of provisional certification beyond January 1, 2023 • Modified provisional certification process and criteria • Added provisional certification extension requests • Clarification to out-of-scope services • Modified required documentation • Administrative/clerical revisions • TX-RAMP Level 1 Certification requirements effective date changed from January 1, 2023 to January 1, 2024
3.0	December 1, 2023	2nd Major Revision: • Added POA&M requirement • Revised StateRAMP/FedRAMP inheritance language • Added/revised determination process • Added/revised high level process • Added transition plan/period • Clarified services not subject to TX-RAMP certification • Revised/aligned control impact baselines • Added TX-RAMP Fast Track Assessment process • Added section addressing new or revised controls • Added Transitional Grace Period • Revised Significant Change requirements • Added Responsibilities Section
3.1	May 14, 2025	1st Minor Revision: • Added GovRAMP Core
4.0	February 12, 2026	3rd Major Revision: • Updated Recertification process • Updated Continuous Monitoring process • Updated Significant Change

		• Made edits for clarity throughout Program Manual • Added Acronyms list

23. Appendix A – TX-RAMP Control Baselines



TX-RAMP Baseline Controls 2.0.xlsx

TX-RAMP Level	Number of Controls/Enhancements Assessed
Level 1	**117**
Level 2	**223**

CONTROL FAMILY	TX-RAMP LEVEL 1	TX-RAMP LEVEL 2
ACCESS CONTROL	9	33
AUDIT AND ACCOUNTABILITY	10	11
AWARENESS AND TRAINING	4	6
CONFIGURATION MANAGEMENT	9	21
CONTINGENCY PLANNING	6	11
IDENTIFICATION AND AUTHENTICATION	10	16
INCIDENT RESPONSE	7	10
MAINTENANCE	4	9
MEDIA PROTECTION	4	7
PERSONNEL SECURITY	8	8
PHYSICAL AND ENVIRONMENTAL PROTECTION	9	17
PLANNING	3	5
RISK ASSESSMENT	6	8
SECURITY ASSESSMENT AND AUTHORIZATION	8	9
SYSTEM AND COMMUNICATIONS PROTECTION	8	23
SYSTEM AND INFORMATION INTEGRITY	6	13
SYSTEM AND SERVICES ACQUISITION	6	16
TOTAL	**117**	**223**

24. Appendix B – Required Documentation

CSPs are required to complete the TX-RAMP Security Plan Workbook as part of the Level 1 and Level 2 assessment submissions. This document will be made available on the TX-RAMP webpage. Additional documentation or artifacts may be requested by TX-RAMP as part of the

assessment process to provide evidence of compliance.

25. Appendix C – Glossary of Terms

Assessment – DIR review of a cloud service provider or state agency request for assessment of a product and all related documentation.
Breach of System Security – As defined by Texas Business & Commerce Code Section 521.053(a).
Cloud Computing Service – As defined by Government Code Section 2063.408(a). A cloud computing service may also be referenced as a cloud offering.
Cloud Service Provider - Vendor of a cloud computing service. A cloud service provider may also be referenced as a cloud computing vendor or a cloud computing services provider or vendor.
Infrastructure as a Service (IaaS) – The meaning assigned by Special Publication 800-145 issued by the United States Department of Commerce National Institute of Standards and Technology, as the definition existed on January 01, 2015.
Low Impact Information Resources – As defined by 1 Texas Administrative Code Section 202.1.
Nonconfidential Data – Information that is not required to be or may not be protected from unauthorized disclosure or public release based on state or federal law or other legal agreement.
Platform as a Service (PaaS) – The meaning assigned by Special Publication 800-145 issued by the United States Department of Commerce National Institute of Standards and Technology, as the definition existed on January 01, 2015.
Private Cloud Deployment – The meaning assigned by NIST SP 800-145 issued by the United States Department of Commerce National Institute of Standards and Technology, as the definition existed on January 01, 2015.
Program Manual – Program manual for the Texas Risk and Authorization Management Program.
Significant Change - a change that is likely to substantively affect the security or privacy posture of a system. Significant changes to a system that may trigger an event-driven authorization action. See NIST Special Publication (SP) 800-37 and NIST SP 800-137 for a complete definition.
State-controlled Data – As defined by 1 Texas Administrative Code Section 202.1.
Software as a Service (SaaS) – The meaning assigned by Special Publication 800-145 issued by the United States Department of Commerce National Institute of Standards and Technology, as the definition existed on January 01, 2015.
GovRAMP (StateRAMP) – The risk and authorization management program, built upon the National Institute of Standards and Technology Special Publication 800-53 and modeled after the FedRAMP program, that provides state and local governments a common method for verification of cloud security.

26. Appendix D – Acronyms

Acknowledgement & Inventory (A&I)

Cloud Security Alliance - Security, Trust, Assurance, and Risk (CSA STAR)
Cloud Service Provider (CSP)
Department of Information Resources (DIR)
Federal Information Security Modernization Act (FISMA)
Federal Risk and Authorization Management Program (FedRAMP)
Health Information Trust Alliance (HITRUST)
Information Security Documentation Inventory (ISDI)
Infrastructure as a Service (IaaS)
Low-impact Software-as-a-Service (LI-SaaS)
National Institute of Standards and Technology (NIST)
Payment Card Industry Data Security Standard (PCI DSS)
Platform as a Service (PaaS)
Project Management Office (PMO)
Software as a Service (SaaS)
System and Organization Controls 2, Type 2 (SOC 2 Type 2)
Texas Risk and Authorization Management Program (TX-RAMP)